From Vulnerability to Compliance: Securing Legacy Systems at Apex Healthcare Solutions

Group number:	Group members:	Assessment date:
Group 71	**1.** Ukwueze Uchenna Collins **2.** Omokanye Fatai O. **3.** Oluwatunmise Adesola Oduntan **4.** Danjuma Titus Sanda **5.** Tolu Samuel Oyelakin **6.** John Tomiwa David **7.** Onyenemere Elvis	Friday, 17th July, 2026

PS: Out of eight (8) group members, the above seven (7) actively participated and contributed with sharing of ideas and resources. All efforts to reach out to the eight (8) individual has proved abortive.

About Apex Healthcare Solutions:

Apex Healthcare Solutions is a medium-sized healthcare technology company that provides digital patient record services to clinics and hospitals.

Private and Confidential:

This report "From Vulnerability to Compliance: Securing Legacy Systems at Apex Healthcare Solutions" is confidential and proprietary to “Apex Healthcare Solutions” and is intended solely for private and confidential use. The contents of this Report, including any information, data, or analysis contained herein, shall not be copied, used, distributed, or disclosed to any third party without the prior express written permission of “Apex Healthcare Solutions”. Unauthorized use, copying, distribution, or disclosure of this Report is strictly prohibited and may violate applicable laws. Legal action may be taken accordingly.

Vulnerability Assessment Report:

Executive Summary 3

- Key findings 3
- Highest-risk vulnerabilities 3
- Recommended controls 3
- Recommended policies 3
- Overall security posture 4

Background 5

Objectives 5

Vulnerability Findings/identification 6

Risk Assessment 13

Recommended controls 15

Security Control Recommendations: 15

Recommended policies 16

GRC (Governance, risk and compliance) Policy Recommendations: 16

Tools Used 18

Conclusion: 18

Executive Summary

- Key findings

A security evaluation of Apex Healthcare Solutions' legacy environments revealed a critical failure to maintain basic security hygiene. Both the Kioptrix and Metasploitable 2 systems run severely obsolete services, unpatched components, and insecure configurations. Multiple vulnerabilities allow unauthenticated network attackers to gain total administrative root access over the host operating systems without valid credentials.

- Highest-risk vulnerabilities

The immediate threats to the organization's environment include:

1. SSL Medium Strength Cipher Suites Supported (SWEET32)
2. Samba Badlock Vulnerability
3. SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption)
4. HTTP TRACE/TRACK Methods Allowed

- Recommended controls

To isolate and remediate these critical exposure points, Apex Healthcare Solutions must deploy the following controls:

1. Strong Encryption Policy
2. Disable SSLv2 and implement Patch Management
3. Regular Security Patch Management
4. Secure Web Server Configuration
5. Firewall and ICMP Filtering Policy

- Recommended policies

To establish long-term security governance, the following policies must be implemented:

1. **Cryptography Policy:** This policy ensures that strong encryption standards are enforced.
2. **Network Security and Monitoring Policy:** This policy protects the network and detects suspicious activity.
3. **Vulnerability and Patch Management Policy**: This policy ensures that software's, servers, and services are regularly reviewed and patched in order to keep systems updated and remove known weaknesses.
4. **Access Control and Authentication Policy:** This policy restricts access to authorized users only.
5. **Secure Configuration/Hardening Policy:** This policy ensures that unnecessary default settings, services, and files are removed

- Overall security posture

The current security posture of these legacy environment is compromised. If left unmitigated, these platforms represent an unacceptably high business risk to operational continuity and regulatory compliance. Because these hosts reside inside an environment providing digital patient record services, the ease of exploitation drastically elevates the threat of data breaches.

Background

Apex Healthcare Solutions recently hired my team (a cybersecurity consulting team) to perform a security review of two legacy systems that were discovered running inside their environment (Kioptrix and Metasploitable 2).

The test consisted of manual and automated (use of commercial/open-source tools) testing to detect and exploit the vulnerabilities discovered/associated with both systems.

Our internal security team conducted vulnerability assessments and identified multiple weaknesses across both systems. After a thorough work, several solutions were proposed to remediate the identified vulnerabilities thereby making the systems more secured. My team was specifically hired because we specialize in performing security checks on systems and networks and delivering quality services.

This Security Assessment was performed by our security team between **4th July, 2026 to 17th July, 2026**.

Objectives

- Identify discovered vulnerabilities.
- Explain the security impact of each vulnerability identified.
- Assess business risk.
- Recommend security controls.
- Recommend organizational policies.
- Present findings in a professional report.

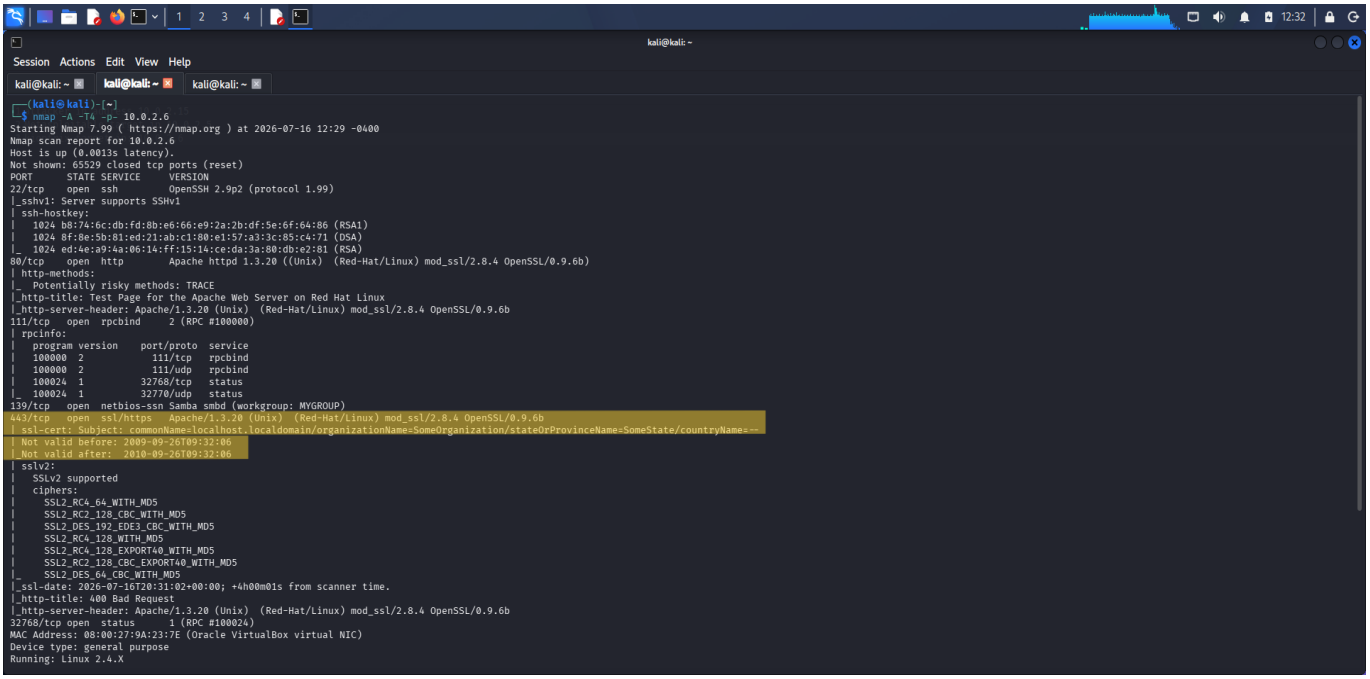
Vulnerability Findings/identification

Three vulnerabilities discovered from **Kioptrix** includes:

A. SSL Medium Strength Cipher Suites Supported (SWEET32)
B. SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption)
C. OpenSSH < 4.0 known_hosts Plaintext Host Information Disclosure

In context:

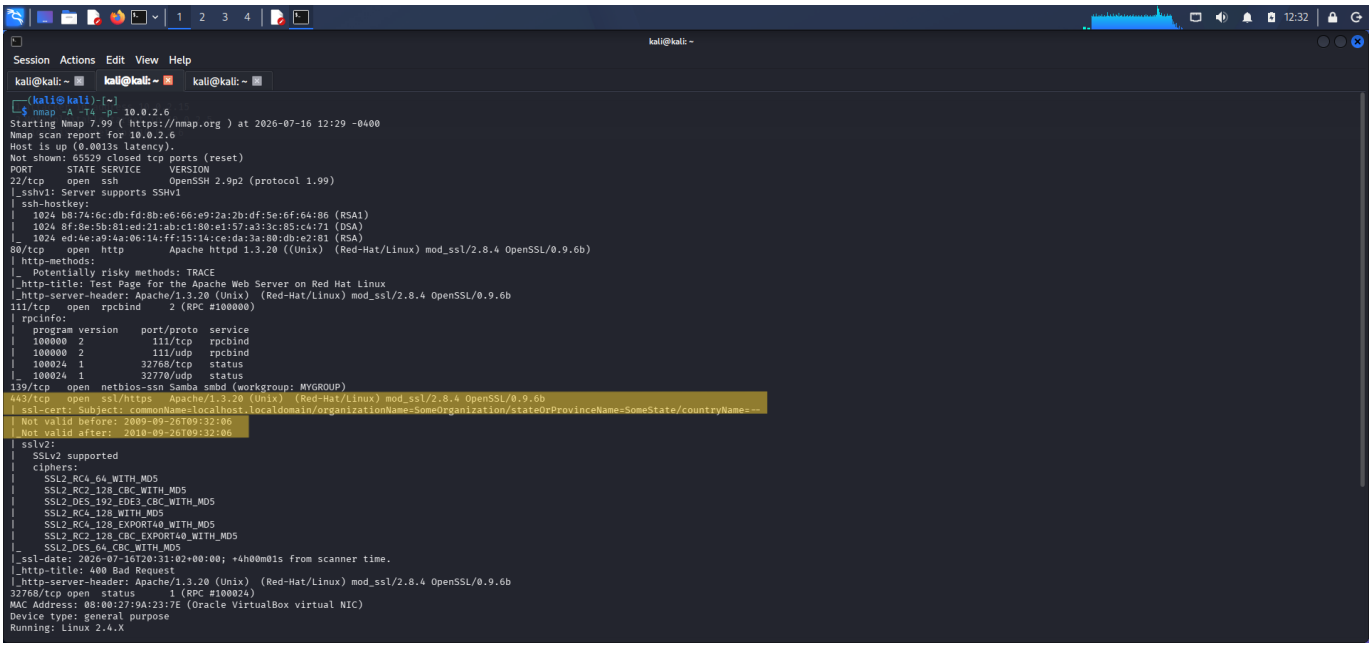
(A)



Vulnerability Name: SSL Medium Strength Cipher Suites Supported (SWEET32)
Affected Service: HTTPS (SSL service) running on the target host (Kioptrix 1) (on port **443/tcp**)
Brief Description: The remote host supports the use of SSL ciphers that offer medium strength encryption. Nessus regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits (or else that uses the 3DES encryption suite) **Note**: That it is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network. Therefore, if you run a server, you should disable triple-DES. This is generally a configuration issue. If you run an old server that doesn't support any better ciphers than DES or RC4, you should upgrade. It can be classified as a "***Man-in-the-Middle attack"*** (an attacker intercepts traffic between the client and server) and a "***Cryptographic attack***".

Potential Attacker Goal: Since Apex "provides digital patient record services", an attacker may attempt to: (a) Hijack a patient's secure session or access confidential information about the patients' (b) Capture encrypted network traffic and gaining access to login credentials of the healthcare professionals at Apex (c) Exploit the SWEET32 weakness to recover sensitive information from encrypted sessions (i.e., a **cryptographic attack**)
Reference info/links to research: http://web.nvd.nist.gov/view/vuln/detail?vulnId=CVE-2016-2183 **(CVE-2016-2183),** http://www.nessus.org/u?df5555f5

(B)



Vulnerability Name: SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption)
Affected Service: Secure Sockets Layer Version 2 (SSLv2) servers (i.e., SSL/TLS) (on port **443/tcp**)
Brief Description: The remote host supports SSLv2 and therefore may be affected by a vulnerability that allows a cross-protocol Bleichenbacher padding oracle attack known as DROWN (Decrypting RSA with Obsolete and Weakened eNcryption). This vulnerability exists due to a flaw in the Secure Sockets Layer Version 2 (SSLv2) implementation, and it allows captured TLS traffic to be decrypted. A **man-in-the-middle attacker** can exploit this to decrypt the TLS connection by

utilizing previously captured traffic and weak cryptography along with a series of specially crafted connections to an **SSLv2** server that uses the same private key.

Further description:

DROWN is a serious vulnerability that affects HTTPS and other services that rely on SSL and TLS, some of the essential cryptographic protocols for Internet security. These protocols allow everyone on the Internet to browse the web, use email, shop online, and send instant messages without third-parties being able to read the communication.

Potential Attacker Goal: DROWN allows attackers to break the encryption and read or steal sensitive communications, including passwords, credit card numbers, trade secrets, or financial data.

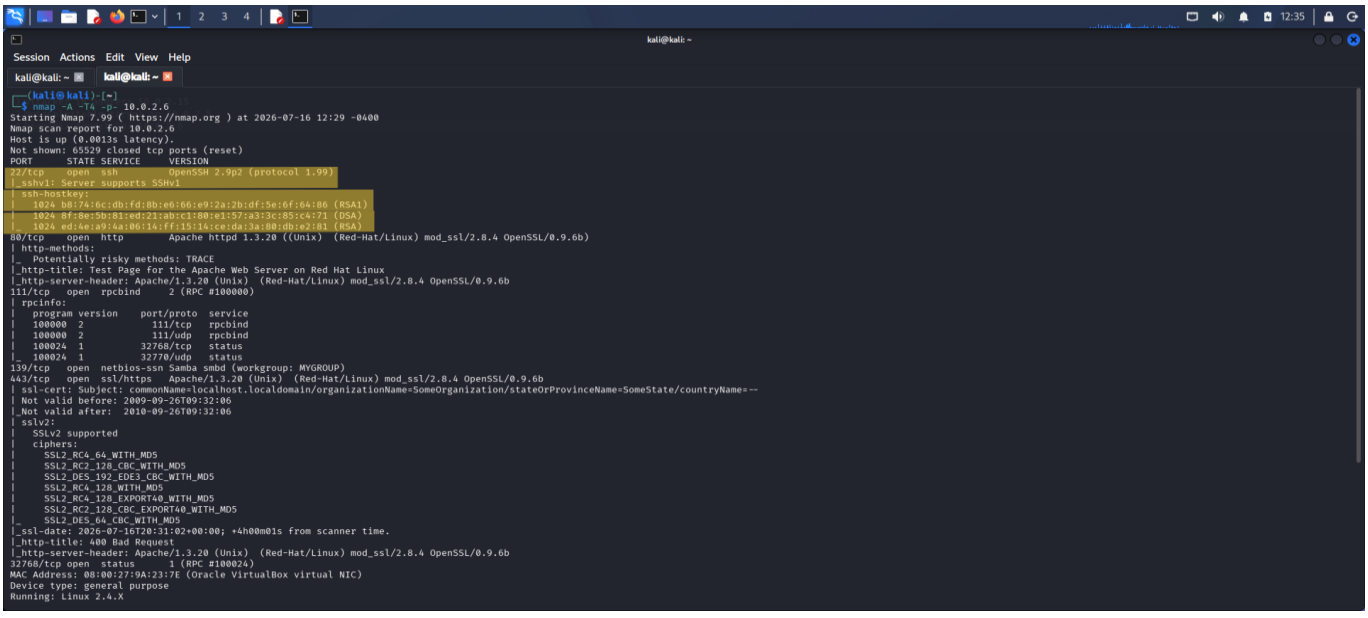
Therefore, Since Apex “provides digital patient record services”, an attacker may attempt to:

(a) Access confidential or sensitive information’s of the patient such as the laboratory results and drug prescriptions
(b) Steal patients’ login credentials or staff usernames and passwords for the purpose of financial fraud, identity theft of the patient/health professionals, and may even launch an attack against Apex Healthcare solutions.

Reference info/links to research:

http://web.nvd.nist.gov/view/vuln/detail?vulnId=CVE-2016-0800, https://drownattack.com/

(C)



Vulnerability Name: OpenSSH < 4.0 known_hosts Plaintext Host Information Disclosure

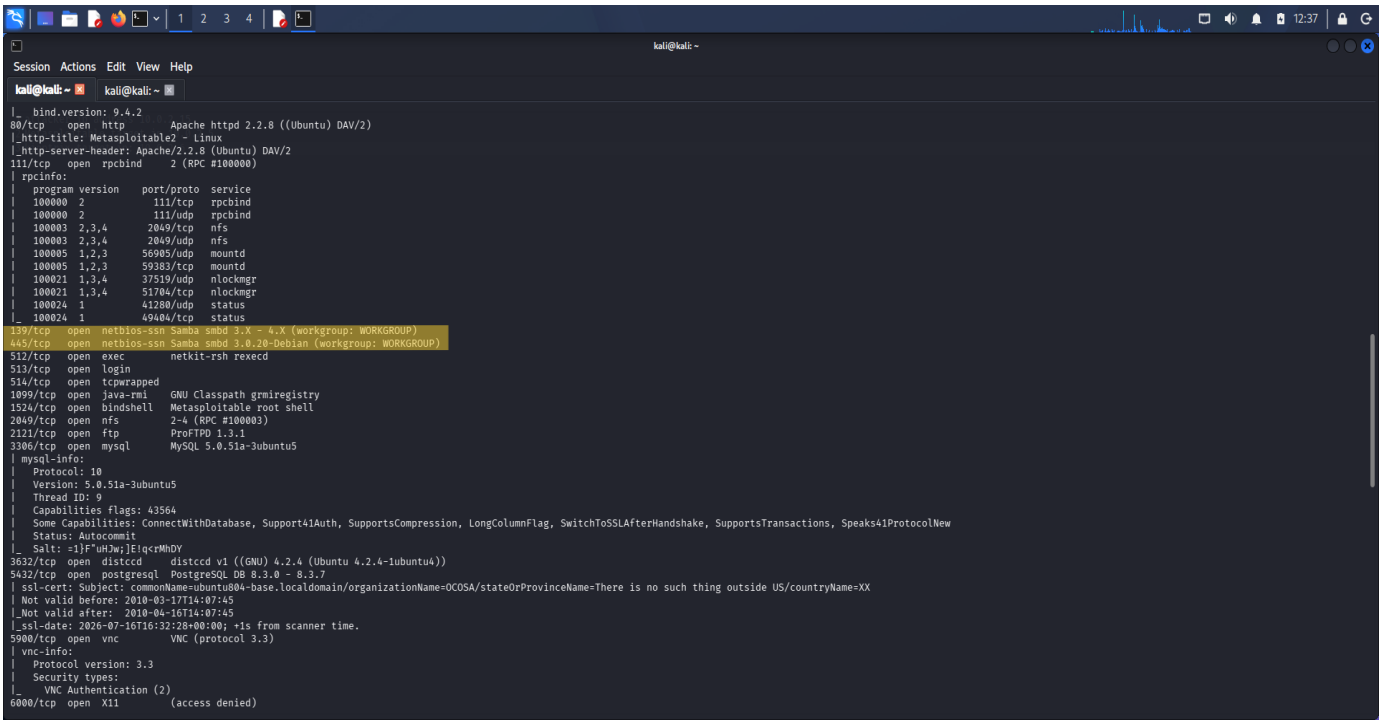
Affected Service: OpenSSH (ssh service) on Port **22/tcp**
Brief Description: The remote host is running a version of OpenSSH prior to 4.0. Versions of OpenSSH earlier than 4.0 are affected by an information disclosure vulnerability because the application stores hostnames, IP addresses, and keys in plaintext in the 'known_hosts' file. A local attacker, exploiting this flaw, could gain access to sensitive information that could be used in subsequent attacks. SSH (Secure Shell), as implemented in OpenSSH before 4.0 and possibly other implementations, stores hostnames, IP addresses, and keys in plaintext in the known_hosts file, which makes it easier for an attacker that has compromised an SSH user's account to generate a list of additional targets that are more likely to have the same password or key. SSH operates on port 22 by default and uses a client-server architecture whereby the SSH client initiates a connection to the SSH server, authenticating the client and establishing a secure session.
Potential Attacker Goal: For Apex Healthcare Solutions, having their IP addresses, hostnames, and keys in plaintext (human-readable words instead of scrambled codes) exposed could lead to an attacker exploring vulnerabilities such as; (a) Gaining root access, accessing the server without resistance, and exfiltration of sensitive patient(s) data (b) The attacker after gaining unauthorized access can also manipulate data for personal gains and install backdoors for future access.
Reference info/links to research: http://web.nvd.nist.gov/view/vuln/detail?vulnId=CVE-2005-2666, https://www.encryptionconsulting.com/ssh-vulnerabilities-how-to-protect/

Three vulnerabilities discovered from **Metasploitable 2** includes:

A. Samba Badlock Vulnerability
B. HTTP TRACE / TRACK Methods Allowed
C. ICMP Timestamp Request Remote Date Disclosure

In context:

(A)



Vulnerability Name: Samba Badlock Vulnerability
Affected Service: Samba server (SMB/CIFC file sharing service) on port **139/445/tcp**
Brief Description: The version of Samba (a CIFS/SMB server for Linux and Unix) running on the remote host is affected by a flaw, known as **Badlock**, that exists in the Security Account Manager (SAM) and Local Security Authority Domain Policy (LSAD) protocols due to improper authentication level negotiation over Remote Procedure Call (RPC) channels. A man-in-the-middle attacker who is able to able to intercept the traffic between a client and a server hosting a SAM database can exploit this flaw to force a downgrade of the authentication level, which allows the execution of arbitrary Samba network calls in the context of the intercepted user, such as viewing or modifying sensitive security data in the Active Directory (AD) database or disabling critical services. "In simple term: As a result, a man in the middle is able to get read/write access to the Security Account Manager Database, which **reveals all passwords** and any other **potential sensitive information**".

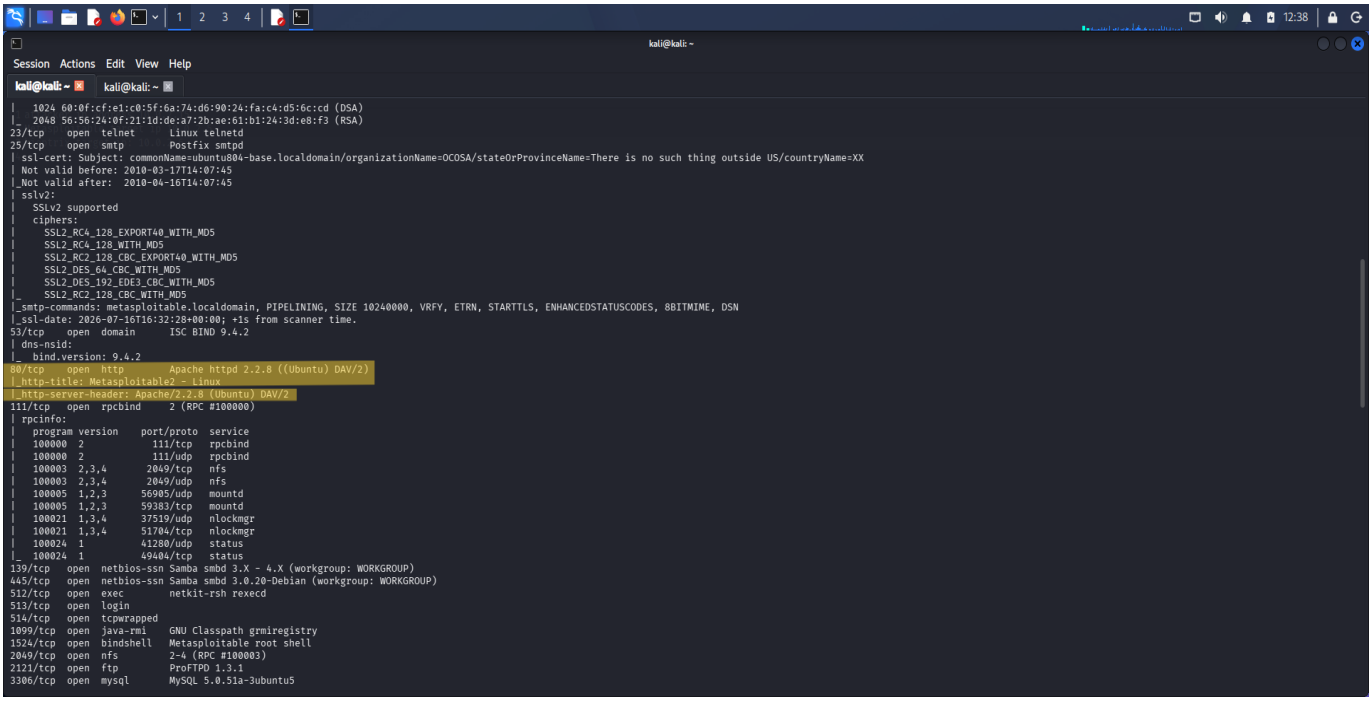
Potential Attacker Goal: An attacker gaining access to all passwords and sensitive information's in Apex Healthcare solution could pose great threat, as the attacker could:

(a) Steal the medical records of the patients and other confidential health information about the patients.
(b) Impersonate legitimate healthcare personnel/staffs to access restricted systems.
(c) Modify the account database, including password hashes.
(d) Maliciously trigger a denial-of-service (DoS) attack on vulnerable infrastructures in order to crash active directory authentication services, or disconnect file servers managing critical patient workflows thereby causing the hospital staffs to lose access to patients' data.

Reference info/links to research:

http://web.nvd.nist.gov/view/vuln/detail?vulnId=CVE-2016-2118,
https://www.samba.org/samba/security/CVE-2016-2118.html

(B)



Vulnerability Name: HTTP TRACE / TRACK Methods Allowed

Affected Service: HTTP server (Apache server) on port **80/tcp**

Brief Description: The remote web server supports the TRACE and/or TRACK methods. TRACE and TRACK are HTTP methods that are used to debug web server connections. The default configuration of BEA WebLogic Server and Express 8.1 SP2 and earlier, 7.0 SP4 and earlier, 6.1 through SP6, and 5.1 through SP13 responds to the HTTP TRACE request, which can allow remote attackers to steal information using cross-site tracing (XST) attacks in applications that are vulnerable to cross-site scripting.

"A local or remote unprivileged user may be able to abuse the HTTP TRACE functionality to gain access to sensitive information in HTTP headers when making HTTP requests to Sun Java System Application servers".
Potential Attacker Goal: For Apex Healthcare Solution, an attacker could; (a) Exfiltrate patients Health Information, alter sensitive patient's records and medical histories. (b) Gain unauthorized access to patient's portal (Electronic Health Record) for identity theft or sale on the dark web.
Reference info/links to research: http://web.nvd.nist.gov/view/vuln/detail?vulnId=CVE-2004-2320, https://download.oracle.com/sunalerts/1000718.1.html

(C)

PS: ICMP operates at the network layer and does not use network ports, therefore vulnerability scanners (such as Nessus) utilizes "0/TCP" as a generic database placeholder to indicate that the flaw applies to the "entire host IP address rather than a specific transport service". This is why there is no image attached to this (below) unlike the rest (above).

Vulnerability Name: ICMP Timestamp Request Remote Date Disclosure
Affected Service: ICMP Timestamp Request (**0/icmp**)
Brief Description: The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols. ICMP information such as (1) netmask and (2) timestamp is allowed from arbitrary hosts.
Potential Attacker Goal: For Apex Healthcare Solution, an attacker could; (a) Defeat time-based authentication schemes (b) Exploit system uptime (i.e., calculate the systems uptime from timestamp variations. If a critical healthcare server shows it has not been rebooted in months, the attacker knows it likely lacks recently released security patches, making it a high value target for ransomware deployment.
Reference info/links to research: **https://www.tenable.com/plugins/nessus/10114, https://nvd.nist.gov/vuln/detail/CVE-1999-0524**

Risk Assessment

Vulnerability	Likelihood	Impact	Risk Score and Risk Rating (according to CVSS)
Kioptrix			
1. SSL Medium Strength Cipher Suites Supported (SWEET32)	**High**	**High**	**7.5 (High)** **Explanation:** Because it involves a "Man-in-the-Middle attack", "cryptographic attack" and could lead to a loss of confidential patient information's.
2. SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption)	**Medium**	**High**	**5.9 (Medium)** **Explanation:** Because it can only expose encrypted communications by exploiting weak SSLv2 configurations, potentially compromising sensitive patient data, but it requires specific vulnerable conditions to be present.
3. OpenSSH < 4.0 known_hosts Plaintext Host Information Disclosure	**Low**	**Medium**	**1.2 (Low)** **Explanation:** Because it only allows an attacker with local or compromised access to read plaintext IP addresses and hostnames of previously connected systems, facilitating internal network reconnaissance and lateral movement toward critical patient data repositories

Metasploitable 2			
4. Samba Badlock Vulnerability	**Medium**	**High**	**7.5 (High)** **Explanation:** Because it allows an attacker to perform Man-in-the-Middle (MitM) attacks against Samba traffic, potentially leading to privilege escalation and unauthorized access to sensitive healthcare files
5. HTTP TRACE / TRACK Methods Allowed	**Medium**	**Medium**	**5.3 (Medium)** **Explanation:** Because it facilitates Cross-Site Tracking (XST) attacks, allowing an attacker to steal active session cookies or authentication headers when a health professional interacts with a malicious website, leading to unauthorized access to medical applications
6. ICMP Timestamp Request Remote Date Disclosure	**Low**	**Low**	**2.1 (Low)** **Explanation:** Because it only reveals the system time information that aids reconnaissance, with limited direct impact on the confidentiality, integrity, or availability of healthcare systems

Recommended controls

Security Control Recommendations:

Vulnerability	Recommended Security Control	How the Control Reduces Risk
SSL Medium Strength Cipher Suites Supported (SWEET32)	Strong Encryption Policy (Disable 3DES, enforce TLS 1.2/1.3)	Eliminates weak cipher suites, preventing attackers from decrypting encrypted communications or stealing sensitive patient data.
SSL DROWN Attack Vulnerability	Disable SSLv2 and implement Patch Management	Prevents exploitation of obsolete SSL protocols and protects encrypted healthcare communications from decryption attacks.
OpenSSH < 4.0 known_hosts Plaintext Host Information Disclosure	Patch Management Process	Upgrading OpenSSH removes the information disclosure vulnerability, preventing attackers from gathering network information for future attacks.
Samba Badlock Vulnerability	Regular Security Patch Management	Installing the vendor security updates removes the authentication flaw and prevents unauthorized access to shared files and patient records.
HTTP TRACE/TRACK Methods Allowed	Secure Web Server Configuration (Disable TRACE/TRACK)	Prevents Cross-Site Tracing attacks that could expose session cookies or authentication credentials.
ICMP Timestamp Request Remote Date Disclosure	Firewall and ICMP Filtering Policy	Blocking ICMP Timestamp requests prevents attackers from obtaining system time information that could aid reconnaissance and later attacks

Recommended policies

GRC (Governance, risk and compliance) Policy Recommendations:

Recommended policies (according to ISO/IEC 27001:2022 Annex A):

1. **Cryptography Policy:**
   (ISO/IEC 27001:2022 Annex A: 8.24 – Use of Cryptography)

Purpose: This policy ensures that strong encryption standards are enforced and weak protocols/ciphers are rejected. It encourages the use of only approved strong encryption methods.
Why Apex Healthcare Solution needs it: Apex Healthcare Solution needs this because patient(s) information must remain confidential while being transmitted across the network.
The Vulnerabilities it helps to mitigate: SSL Medium Strength Cipher Suites Supported (SWEET32) and Secure Sockets Layer Version 2 (SSLv2) servers (DROWN).

2. **Secure Configuration/Hardening Policy:**
   (ISO/IEC 27001:2022 Annex A: 8.9 – Configuration Management)

Purpose: This policy ensures that unnecessary default settings, services, and files are removed.
Why Apex Healthcare Solution needs it: Apex Healthcare Solution needs this because default pages, sample apps, and debugging features gives attackers useful information.
The Vulnerabilities it helps to mitigate: HTTP TRACE / TRACK Methods Allowed, ICMP Timestamp Request Remote Date Disclosure.

3. **Vulnerability and Patch Management Policy:**
   (ISO/IEC 27001:2022 Annex A: 8.8 – Management of Technical Vulnerabilities)

Purpose: This policy ensures that software's, servers, and services are regularly reviewed and patched in order to keep systems updated and remove known weaknesses.
Why Apex Healthcare Solution needs it: For an healthcare institution, Apex Healthcare systems are high-value targets for attackers, and an outdated software can expose patient data.
The Vulnerabilities it helps to mitigate: Samba Badlock Vulnerability, OpenSSH < 4.0 known_hosts Plaintext Host Information Disclosure, Secure Sockets Layer Version 2 (SSLv2) servers (DROWN).

4. **Access Control and Authentication Policy:**
   (ISO/IEC 27001:2022 Annex A: 5.15 – Access Control)

Purpose: This policy restricts access to authorized users only.
Why Apex Healthcare Solution needs it: Apex Healthcare Solutions needs it because Staff(s) and patient(s) systems should not be exposed to unauthorized users.
The Vulnerabilities it helps to mitigate: It helps to mitigate Samba Badlock vulnerability and attacks that could lead to unauthorized access to shared files or healthcare records.

5. **Network Security and Monitoring Policy:**
   (ISO/IEC 27001:2022 Annex A: 8.20 – Network Security)

Purpose: This policy protects the network and detects suspicious activity. It does this by using firewalls, segmentation and continuous monitoring.
Why Apex Healthcare Solution needs it: Apex Health care solution need this because early detection and network filtering will reduce the chances of successful attacks on healthcare records.
The Vulnerabilities it helps to mitigate: ICMP Timestamp Request Remote Date Disclosure, HTTP TRACE / TRACK Methods Allowed, and service exposure through SSH and Samba.

Tools Used

The Security team uses a combination of manual testing and commercial/open-source tools as part of its penetration testing methodology. This is accompanied by custom scripts to ensure optimum results.

The following tools are used for the testing.

- ✓ Kali Linux
- ✓ Kioptrix 1 and Metasploitable 2 sandbox
- ✓ Nessus
- ✓ Mozilla Firefox browser
- ✓ Microsoft word (for documentation)

Conclusion:

The structural vulnerabilities uncovered within Apex Healthcare Solutions' represents severe operational liabilities. If left unmitigated, these flaws could provide attackers with trivial, unauthenticated root-level control, drastically heightening the probability of a catastrophic patient data breach.

By following and implementing the “security control recommendations” and “GRC (Governance, risk and compliance) policy recommendations” outlined above, Apex Healthcare Solutions can effectively bridge the gap between active vulnerability and robust regulatory compliance. These immediate remediation steps are vital to safeguard infrastructure/healthcare assets, protect consumer (patients’) trust, and isolate critical healthcare host networks from emerging threats.